Witnessed Policy: Quorum-Committed, Edge-Validated Policy for SD-WAN

Blessing Honmane
SafeLinx Technology
blessing.honmane@safelinx.ng

***Abstract*—An SD-WAN controller is a single point of policy authority. We keep it trusted for availability only: policy is a signed hash chain validated at every edge (layer 1), and a two-phase quorum commit with administrator-started round change makes the chain fork-free at enforcement (layer 2). With n edges, at most b Byzantine and c further offline, quorum $T = \lceil (n + b + 1)/2 \rceil$ is safe and live iff $n \geq 3b + 2c + 1$, so each offline edge costs two extra edges instead of three. We prove unique commit, show that one-phase commit with claim-based recovery is unsafe, bound revocation, and check the core with TLA$^+$/TLC (safety, liveness, trace validation) and a prototype of real edge processes with WireGuard and nftables, against baselines and a 30-record incident corpus.**

I. Introduction

A stolen controller credential should not be able to rewrite a network's policy, and tolerating offline branches should not require extra sites. Witnessed Policy meets both: the controller is untrusted for safety, and the quorum is sized by separating Byzantine edges (b) from offline ones (c). The consequence is that $n \geq 3b + 2c + 1$ edges suffice instead of $3(b+c) + 1$. For n=12 edges, one compromised and four offline (b=1, c=4), the quorum is T=7 and a commit is possible with probability

$$\mathrm{Av}(n, b, Q, a) = \sum_{k=Q}^{n-b} \binom{n-b}{k} a^k (1-a)^{n-b-k} \qquad (1)$$

(Q the quorum, a per-edge availability, Byzantine edges silent), whereas treating offline edges as Byzantine would need $n \geq 16$ and, at n=12, lowers availability from 0.997 to 0.910 at a=0.9 (Table I).

Positioning. We do not propose a new Byzantine agreement protocol. The quorum arithmetic is UpRight's [1], the round change follows PBFT [2], and the per-round prepare lock follows FastPay [3]. What is new is their use for SD-WAN policy enforcement: edges validate each entry against the policy rules (tiered approvals, protected invariants), decide each slot themselves and enforce only committed entries, so a compromised controller cannot forge or fork policy. We also bound revocation and freshness for the resulting data plane and measure its cost with real WireGuard and nftables enforcement.

TABLE I
Commit availability, eq. (1): separated quorum $T(n, b)$ vs. simple $T(n, b+c)$.

(n, b, c)	a	T_{sep}	Av_{sep}	Av_{simple}
(12,1,4)	0.90	7	0.9972	0.9104
(12,1,4)	0.95	7	0.9999	0.9848
(16,1,4)	0.90	9	0.9997	0.9873
(20,2,6)	0.90	12	0.9988	0.9018

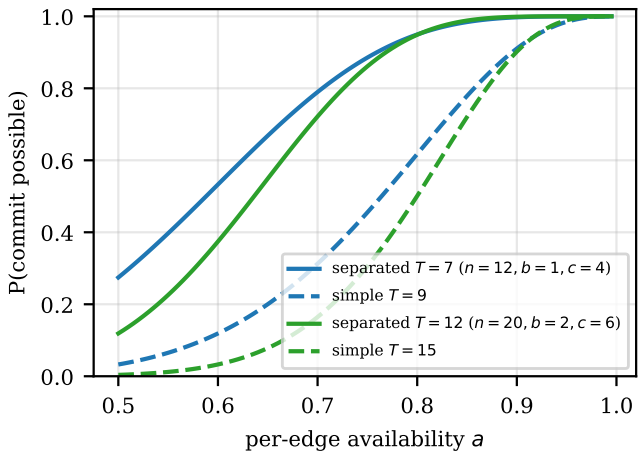


Fig. 1. Commit availability vs. per-edge availability, separated vs. simple quorum.

Contributions. (1) Unique commit under $\leq b$ Byzantine edges, across rounds and epochs (Thm. 1). (2) The mixed bound for this protocol (Prop. 2), safe iff $Q \geq T$ and live iff $Q \leq n-b-c$, and a proof that one-phase commit with claim-based recovery is unsafe (Prop. 3). (3) Lost-record accounting and an observer rule (Prop. 4). (4) Certified time and revocation bounds (Props. 7, 8). (5) TLC safety, liveness and trace-validation checks; baselines S0 and S3; an attack-model simulation, an outage simulation and a 30-record incident corpus; and a prototype whose edges are real processes with WireGuard tunnels and nftables enforcement (Sections VIII, IX). Motivation: controller compromise is a recurring SD-WAN threat [4]–[6].

Not claimed. The node bound is UpRight's $2u+r+1$ with u=b+c, r=b; collusion of $\geq m$ administrators is out of scope. **Scope.** The paper offers a design, proofs, model checking and a single-host prototype. The incident corpus was coded by two coders (κ=1.00). A multi-host deployment is future work. **Artifact.** Code, specifications, traces and the incident corpus are at https://github.com/honbles/Witnessed-Policy.

II. Mechanism in One Page

Intuition. Edges, not the controller, decide each policy slot. An edge *prepares* at most once per round; T prepares form a *prepared certificate* (PC), proof that no other value can be prepared in that round. Only an edge holding a PC *commits*; T commits form a *commit certificate* (CC), and edges enforce an entry only with a CC. If proposals split, no PC forms and the slot is stuck. One administrator then starts a *round change*: edges promise to ignore lower rounds and report the highest PC they hold, and the new round must adopt the value of the highest reported PC. A value that may already have committed is therefore never abandoned, because any T reports overlap the T committers in an honest edge (Fig. 2).

III. Model

A. Entities, faults, chain

Edges $\mathcal{E} = \{1, \dots, n\}$; Byzantine $\mathcal{B} \subseteq \mathcal{E}$, $|\mathcal{B}| \le b$; offline $C \subseteq \mathcal{E} \setminus \mathcal{B}$, $|C| \le c$; honest $\mathcal{H} = \mathcal{E} \setminus \mathcal{B}$; up $U = \mathcal{E} \setminus (\mathcal{B} \cup C)$. Administrators $\mathcal{A}$; entry tier $\theta(\eta) \in \{\mathsf{L0}, \mathsf{L1}, \mathsf{L2}, \mathsf{L3}, \mathsf{R}\}$ with threshold m_θ. Honest clocks differ by at most σ.

$$T = \left\lceil \tfrac{n+b+1}{2} \right\rceil. \tag{2}$$

Entry $\eta_s = (s, h_{s-1}, op, \theta, \mathsf{Ap})$, $h_s = \mathrm{hash}(\eta_s)$, Ap the approvals. State $S_s = \mathrm{apply}(S_{s-1}, \eta_s)$, S_0 from genesis G_0. $\mathrm{WF}(S)$ says the state is well formed, $\mathrm{Prot}(S)$ that no grant in S crosses a protected pair, $\Gamma(S)$ is the set of grants in S, $\mathrm{Tr}(f)$ the transit sites of a flow f, and $\mathrm{inst}_u(\gamma)$ that site u has installed grant γ.

$$\mathrm{Auth}(\eta) \Leftrightarrow \left|\{\alpha \in \mathcal{A} : \mathrm{vrf}_\alpha(\eta)\}\right| \ge m_{\theta(\eta)}, \tag{3}$$

$$\mathrm{Valid}(S, \eta) \Leftrightarrow \mathrm{Auth}(\eta) \wedge \mathrm{WF}(S') \wedge \mathrm{Prot}(S'), \quad S' = \mathrm{apply}(S, \eta). \tag{4}$$

Valid is a deterministic function of the shared prefix. The protected set $\Pi(S') = \Pi(S)$ unless *op* removes an invariant at tier L3.

B. Attestations, certificates, rules

For slot s, round r, digest v: $P_{s,r}(v)$, $K_{s,r}(v) \subseteq \mathcal{E}$ are the edges that issued $\langle \mathrm{prep}, s, r, v\rangle$, $\langle \mathrm{com}, s, r, v\rangle$.

$$\mathrm{PC}(s, r, v) \Leftrightarrow |P_{s,r}(v)| \ge T, \tag{5}$$

$$\mathrm{CC}(s, r, v) \Leftrightarrow |K_{s,r}(v)| \ge T, \tag{6}$$

$$\mathrm{Committed}(s, v) \Leftrightarrow \exists r : \ \mathrm{CC}(s, r, v). \tag{7}$$

Edges enforce η_s only if $\mathrm{Committed}(s, \mathrm{hash}(\eta_s))$. Fix s. An honest edge e keeps a durable promise π_e (init 0) and the set $\mathcal{W}_e$ of prepared certificates it holds. Certificates are unforgeable; Byzantine edges may sign anything; every attestation, promise and report is durable before it is sent.

- R1 $\mathrm{prep}(r, v)$ iff $\mathrm{Valid}(S_{s-1}, v) \wedge \pi_e \le r \wedge$ no prior prepare of e in round $r \wedge (r{=}0 \vee (r, v) \in \mathrm{Res})$; then $\pi_e \leftarrow r$.
- R2 $\mathrm{com}(r, v)$ iff $(r, v) \in \mathcal{W}_e \wedge \pi_e \le r \wedge$ no prior commit of e in round r.
- R3 $\mathrm{promise}(r')$ iff $r' > \pi_e$; then $\pi_e \leftarrow r'$ and e reports $\rho_e(r') = \max_{\mathrm{round}}\{(r, v) \in \mathcal{W}_e : r < r'\}$ or $\perp$.
- R4 $(r', v) \in \mathrm{Res}$ iff an admin-signed $\mathrm{RES}(r', \mathcal{R})$ carries $|\mathcal{R}| \ge T$ edge-signed reports bound to r', each holding only certificates of round $< r'$, and $v \in \mathrm{Sel}(\mathcal{R})$.
- A5 An edge attests at slot s only if it holds $\eta_1..\eta_{s-1}$ with certificates.

$$\mathrm{Sel}(\mathcal{R}) = \begin{cases} \{v^\star\} & \text{if a certificate is carried} \\ & (v^\star \text{ of the max round}) \\ \text{any valid } v & \text{otherwise.} \end{cases} \tag{8}$$

IV. Safety

Lemma 1 (intersection)**.** $|Q_1|, |Q_2| \ge T \Rightarrow |Q_1 \cap Q_2| \ge 2T - n \ge b + 1$, *so* $(Q_1 \cap Q_2) \setminus \mathcal{B} \ne \emptyset$.

Proof. $|Q_1 \cap Q_2| \ge |Q_1| + |Q_2| - n$ and $2T \ge n + b + 1$. □

Lemma 2 (one prepared value per round)**.** $\mathrm{PC}(r, v) \wedge \mathrm{PC}(r, w) \Rightarrow v = w$.

Proof. By Lemma 1 some honest $e \in P_r(v) \cap P_r(w)$; R1 allows one prepare per round. □

Lemma 3 (commit implies prepared)**.** $\mathrm{CC}(r, v) \Rightarrow \mathrm{PC}(r, v) \wedge \mathrm{Valid}(S_{s-1}, v)$.

Proof. (1) $|K_r(v)| \ge T > b$, so $K_r(v)$ contains an honest edge e. (2) By R2, e issued $\langle \mathrm{com}, s, r, v\rangle$ only after holding a prepared certificate for (r, v), that is, T signed prepares for v in round r. Certificates are unforgeable, so $|P_{s,r}(v)| \ge T$ and $\mathrm{PC}(r, v)$ holds. (3) At most b of these prepares are Byzantine, so at least $T - b \ge 1$ come from honest edges. By R1 each prepared v only after Valid held on its prefix, and that prefix is the unique S_{s-1} (A5 and the induction on slots in Thm. 1). Hence $\mathrm{Valid}(S_{s-1}, v)$. □

In words. No two different entries are ever enforced for the same slot, whatever the controller does, provided at most b edges are Byzantine.

Theorem 1 (unique commit)**.** *If* $|\mathcal{B}| \le b$ *and honest edges obey R1–R4 with durable records, then* $\forall s : \ |\{v : \mathrm{Committed}(s, v)\}| \le 1$.

Proof. We argue for slot s by induction on s: slots below s have a unique committed entry, so every honest edge that attests at s (A5) holds the same prefix and Valid is the same predicate at all of them.

Claim $\mathcal{I}(\rho, v)$: $\mathrm{CC}(\rho, v) \Rightarrow \forall r \ge \rho, \ \forall w : \ \mathrm{PC}(r, w) \Rightarrow w = v$. Induct on r.

Base $r = \rho$. Lemma 3 gives $\mathrm{PC}(\rho, v)$ and Lemma 2 gives $w = v$.

Step $r > \rho$. Let $\mathrm{PC}(r, w)$ and assume $\mathcal{I}(\rho, v)$ for the rounds in $[\rho, r-1]$. (1) At least one honest edge prepared w in round r, since $T > b$. As $r > 0$, R1 gives $(r, w) \in \mathrm{Res}$, so some admin-signed $\mathrm{RES}(r, \mathcal{R})$ has $|\mathcal{R}| \ge T$ and $w \in \mathrm{Sel}(\mathcal{R})$. (2) Let $K = K_\rho(v)$. By Lemma 1 some honest $e^\star$ lies in $\mathcal{R} \cap K$. (3) $e^\star$ committed in round ρ *before* it reported: its report sets $\pi_{e^\star} \ge r > \rho$ (R3), and R2 requires $\pi \le \rho$ to commit in round

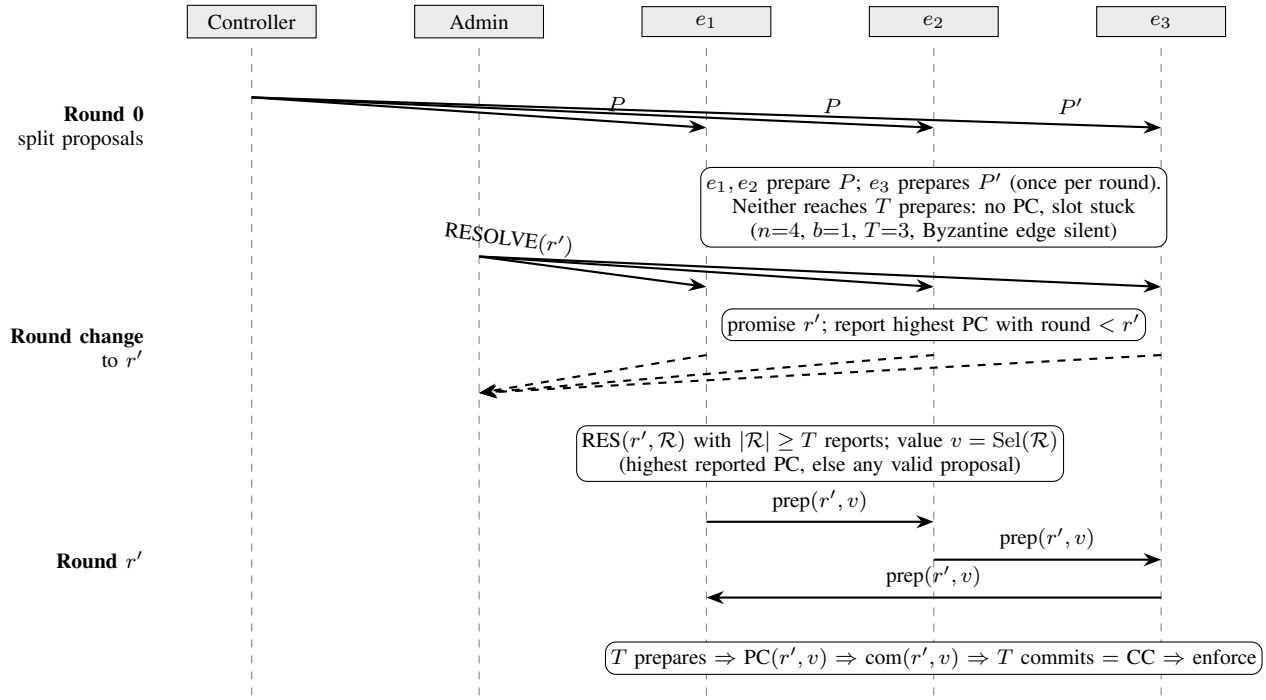


Fig. 2. Message flow for n=4, b=1, T=3 with the Byzantine edge silent (an active one could complete a PC for P): a split round 0 is stuck; an administrator starts round r'; the value is forced by the highest reported PC, then prepare→commit as usual.

ρ. (4) By R2, $e^\star$ then held a prepared certificate for (ρ, v). Certificate sets only grow, so its report carries a certificate of some round in $[\rho, r-1]$, the highest it holds below r. (5) Every certificate in $\mathcal{R}$ has round $< r$. By $\mathcal{I}$ on $[\rho, r-1]$, each one of round $\geq \rho$ is for v, whoever reported it, because certificates cannot be forged. By (4) the maximum-round certificate in $\mathcal{R}$ has round $\geq \rho$, and certificates of one round carry one value (Lemma 2). So $\mathrm{Sel}(\mathcal{R}) = \{v\}$ and $w = v$.

Conclusion. If $\mathrm{Committed}(s, v)$ and $\mathrm{Committed}(s, w)$, say $\mathrm{CC}(\rho_v, v)$ and $\mathrm{CC}(\rho_w, w)$ with $\rho_v \leq \rho_w$, then $\mathrm{PC}(\rho_w, w)$ by Lemma 3, hence $w = v$ by $\mathcal{I}(\rho_v, v)$. □

In words. Edges never disagree about history, and every enforced entry carries the approvals its tier requires and respects the protected invariants. A forged controller entry is never enforced.

Corollary 1 (no fork; authorization; invariants)**.** *(a) For honest e, e', $\mathrm{enf}_e(s) = v$ and $\mathrm{enf}_{e'}(s) = v'$ imply $v = v'$, so enforced histories are prefix-comparable. (b) $\forall s:\ \mathrm{Auth}(\eta_s) \wedge \mathrm{Prot}(S_s)$ and $\Pi(S_s) \supseteq \Pi(S_0)$ minus* L3*-removed elements; an entry with $|\mathsf{Ap}| < m_\theta$ is never committed.*

Proof. (a) Enforcement needs a CC; apply Thm. 1. (b) Lemma 3 and induction on s (unique S_{s-1}). A forged entry fails Auth, so only $\leq b < T$ edges attest. □

In words. Membership changes cannot open a window for two histories.

Proposition 1 (epochs)**.** *Membership M_s is a function of S_{s-1}; ENROLL/EVICT in η_s act from s+1; attestations of other epochs are ignored. If $|\mathcal{B} \cap M_s| \leq b_s$ with $T_s = T(|M_s|, b_s)$ for all s, Thm. 1 holds for all s.*

Proof. Induction on s: S_{s-1} unique $\Rightarrow$ M_s unique $\Rightarrow$ slot s is an instance of Thm. 1 with (M_s, T_s). □

In words. T is the smallest safe quorum, and $n-b-c$ is the largest quorum that is still reachable when c edges are offline; a feasible quorum exists exactly when $n \geq 3b + 2c + 1$.

Proposition 2 (tightness)**.** *For quorum Q: (a) safety against all $|\mathcal{B}| \leq b$ iff $Q \geq T$; (b) liveness with $\mathcal{B}$ silent and $|C| = c$ iff $Q \leq n - b - c$. Hence a feasible Q exists iff*

$$n \geq 3b + 2c + 1, \tag{9}$$

versus $n \geq 3(b+c)+1$ if offline edges are treated as Byzantine.

Proof. (a) "If" is Thm. 1. If $Q < T$ then $2Q - n \leq b$; choose Q_1, Q_2 with $|Q_1 \cap Q_2| \leq b$ and let $\mathcal{B} \supseteq Q_1 \cap Q_2$ sign both $v \neq w$: two certificates. (b) A commit needs Q attestations from U. Combine: $\lceil \frac{n+b+1}{2} \rceil \leq n-b-c \iff n \geq 3b+2c+1$ (RHS integer). □

Example: n=12, b=1, c=4 gives T=7 $= n-b-c$; the simple rule needs $n \geq 16$.

In words. One-phase commit whose recovery relies on uncertified reports cannot be repaired by enlarging the quorum: such reports can be forged. Faster one-phase protocols exist at larger n, for example FaB [7] with $n \geq 5b + 1$.

Proposition 3 (claim-based one-phase commit is unsafe)**.** *Let commit need $Q \in [T, n - b - c]$ attestations and RES select*

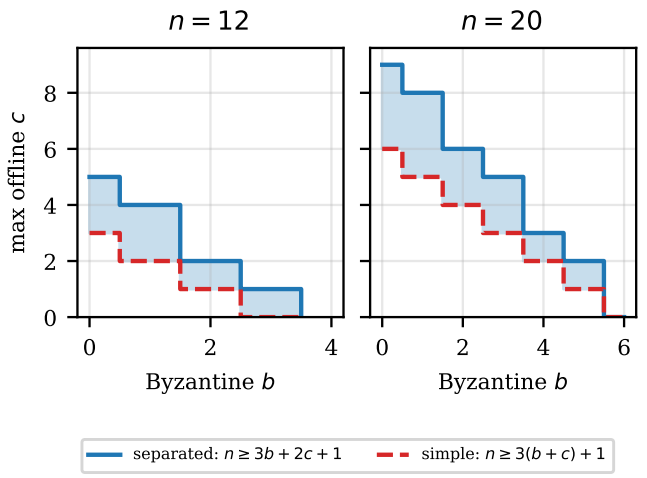


Fig. 3. Tolerable (b, c): separated (solid) vs. simple (dashed); shaded gain.

the value of the highest-round claimed *last attestation (no certificates). For every n and $b \geq 1$ there is a run with two committed values.*

Proof. Round 0: take K with $|K| = Q$, $z \in K \cap \mathcal{B}$, $K \setminus \{z\} \subseteq U$ (possible since $Q-1 \leq n-b-c$); K attests v, so v commits. $\mathrm{RES}(2, \mathcal{R})$, $|\mathcal{R}| = Q$, $z \in \mathcal{R}$: honest members report $(0, v)$ or $\perp$; z reports the forged $(1, w)$. The highest claim is $(1, w)$, so w is selected. In round 2 the $n - b - c \geq Q$ up honest edges all attest w (R1: $\pi \leq 2$, $(2, w) \in \mathrm{Res}$, locking is per round), so w commits without any Byzantine help. (With $\mathcal{B}$ the margin is $n - c \geq Q + b$.) □

TLC finds the same double commit for n=4, 5 with b=1, and under a "b+1 matching claims" rule for n=4, 5, 6 (Table II); that rule fails on ties between honest and Byzantine-supported claims. Prepared certificates remove the dependence on claims. *In words.* An edge that forgets what it attested must be counted among the Byzantine ones, unless it sits out until the chain has moved past that slot.

Proposition 4 (lost attestation record)**.** *Let $L \subseteq \mathcal{H}$ lose records (and may re-attest). (i) Thm. 1 holds with b replaced by $b' \geq |\mathcal{B}| + |L|$ and $T = T(n, b')$. (ii) If $T = T(n, b)$, $|\mathcal{B}| + |L| = b + 1$ and $n + b$ is odd, unique commit can fail. (iii) Observer rule: $\ell \in L$ with persisted head h_ℓ (heads are persisted before any attestation above them) attests only at slots $\geq h_\ell + 2$. Then ℓ never double-attests; it counts in c, not b, and the bound becomes $n \geq 3b + 2(c + |L|) + 1$.*

Proof. (i) The proof of Thm. 1 uses only that $\leq b'$ edges violate R1–R3. (ii) $2T - n = b + 1$ when $n + b$ is odd; take $\mathcal{B} \cup L$ as the overlap (TLC: n=4, b=1). (iii) By A5, pre-loss attestations are at slots $\leq h_\ell + 1$. □

In words. Without layer 2, a stolen key plus a partitioning controller makes edges enforce different policies; with layer 2 this never happens.

Proposition 5 (layer 1 alone forks)**.** *Under layer 1 only, with $m_\theta = 1$ and one stolen key, the controller can sign $\eta \neq \eta'$ on one base and partition $\mathcal{E} = \mathcal{E}_1 \sqcup \mathcal{E}_2$. The divergence*

$$D(t) = \left|\{(e, e') : \mathrm{enf}_e(s) \neq \mathrm{enf}_{e'}(s)\}\right| = |\mathcal{E}_1||\mathcal{E}_2| \qquad (10)$$

holds until the first cross-side head arrives, unbounded under a persistent partition. Under layer 2, $D \equiv 0$ (Cor. 1).

Proof. With $m_\theta = 1$ both entries satisfy Auth; Valid depends only on the shared prefix, so each side validates and enforces its entry. Layer 2 excludes this by Thm. 1. □

V. Liveness

In words. A stuck slot always recovers when enough edges are up and one administrator is available.

Proposition 6 (round-change liveness)**.** *If $n - b - c \geq T$, messages among U are eventually delivered (edges retransmit issued attestations when a proposal is re-sent), and one administrator signs RES, a stuck slot commits within two rounds.*

Proof. $|U| \geq T$ reports exist (R3); Sel yields a value; U prepares and commits it (R1, R2). □

VI. Time, Freshness, Revocation

In words. A compromised controller cannot move a certified time outside the range of honest timestamps, whose width is the honest clock skew plus the spread of their issue times.

Proposition 7 (certified time)**.** *Let $k \geq T$ timestamps $t_{(1)} \leq \cdots \leq t_{(k)}$ of a CC contain $\leq b$ Byzantine ones. For $n \geq 3b+1$ the median $\tilde{t} = t_{(\lceil k/2 \rceil)}$ satisfies $\min_{\mathcal{H}} t \leq \tilde{t} \leq \max_{\mathcal{H}} t$, a range of width at most σ plus the spread of the issue times of the honest timestamps.*

Proof. $T \geq 2b+1$, so $\lceil k/2 \rceil \geq b+1$ and $\lfloor k/2 \rfloor + 1 \geq b+1$: both the lowest $\lceil k/2 \rceil$ and the highest $\lfloor k/2 \rfloor + 1$ values contain an honest one. □

Edges sign heads (s, h_s, t) every g. The target slot $s^\star(t) = \max\{s : |\{e : \mathrm{head}_e \geq s\}| \geq b+1\}$ is committed (one honest voucher). An edge is *fresh* iff it holds heads from $\geq T$ distinct edges (itself counted once) within Δ and $\mathrm{applied}_e \geq s^\star$, with $s^\star$ computed over the heads it holds. A grant is effective at e before its lease expires, or later while e is fresh. Requiring only b+1 heads would be unsound: a partitioned minority could vouch for itself and never learn of a revocation.

In words. A connected edge applies a revocation within about one gossip interval; an edge that is cut off stops at lease expiry.

Proposition 8 (revocation)**.** *Let a revocation commit at t_c and let d_{enf} be the time to remove forwarding and sessions. (a) If e has delay-δ links to $\geq b + 1$ honest edges, $t_{\mathrm{eff}}(e) \leq t_c + 4\delta + g + d_{\mathrm{enf}}$. (b) If e is not fresh at any time $\geq \lambda_\gamma$, the lease expiry of the revoked grant γ (for instance because it holds fewer than T heads, being cut off from more than $n-T$ other edges), then $t_{\mathrm{eff}}(e) \leq \lambda_\gamma + \sigma + d_{\mathrm{enf}}$.*

TABLE II
TLC RESULTS (DISTINCT STATES).

Configuration	Result	States
n=4, b=1, T=3, rounds 0..1	no violation	72,863
same, rounds 0..2 (abstract)	clean, exhaustive	6,542,584
n=7, b=2, T=5, rounds 0..1 (abstract)	clean, exhaustive	1,048,806
lost record, $T(n, b)$, n=4	violation	–
lost record, $T(n, b{+}1) = 4$	no violation	61,983
lost record, observer, T=3	no violation	426,322
n=6, b=1, c=1 (bound tight)	commit reachable	344
n=5, b=1, c=1; n=6, b=1, c=2	no commit	32; 32
one-phase highest, n=4, 5	double commit	917; 5,175
one-phase matching, n=4, 5, 6	double commit	1,031; 7,757; 7,730
liveness under fairness, n=4, rounds 1; 2	holds	2,040; 158,458
liveness, T above the honest edges	fails (control)	216

Proof. (a) Commit attestations reach linked honest edges by $t_c{+}\delta$; their heads reach e by $t_c{+}2\delta{+}g$; fetching costs 2δ. (b) A grant is effective at a non-fresh edge only before its lease expires, which e judges with clock skew at most σ; removing forwarding and sessions then takes d_{enf}. Freshness is a sufficient condition for staying effective beyond the lease, so no other case arises when e is not fresh. □

VII. Enforcement and Bootstrap

Flow f is forwarded at slot s iff $\exists\gamma \in \Gamma(S_s) : f \in \gamma \wedge \forall u \in \{\text{src}, \text{dst}\} \cup \text{Tr}(f) : \text{inst}_u(\gamma)$ (two-sided, transit; default deny otherwise). Edge state $\in \{\text{UNPROV}, \text{ANCHORED}, \text{SYNC}, \text{VERIFIED}, \text{VOTING}\}$ with

$$\text{UNPROV} \to \text{ANCHORED} \iff \text{hash}(G_0) = h_{\text{oob}}, \quad (11)$$

$$\text{attest}_e(s) \Rightarrow \text{st}_e = \text{VOTING} \wedge s > \text{head}_e, \quad (12)$$

$$\text{Fwd}_e \neq \emptyset \Rightarrow \text{st}_e \geq \text{VERIFIED}. \quad (13)$$

A substituted genesis fails the first test; such an edge is counted in b.

VIII. Machine-Checked Results

`WitnessedPolicy.tla` models one slot: honest edges explicit, Byzantine edges as maximal-power counts, durable records, promise/report/RES, offline edges, record loss. Checked: UniqueCommit, NoDoubleAttest, PreparedBeforeCommit, PromiseRespected. For three rounds (n=4) and for n=7 (two rounds) we use `WitnessedPolicyAbs.tla`, in which an edge learns certificates instantly and reports any existing lower-round certificate at least as high as its own commits; this over-approximates the explicit-knowledge model, and as a negative control it flags the violation at T=2. TLC runs with 8 workers on an 8-vCPU server and quotients by edge permutations and by swapping the two values; counts for violations are where TLC stopped. An independent Python model (edge symmetry only) reaches 145,708 states; 18 of them are invariant under the value swap, and Burnside's lemma gives $(145{,}708{+}18)/2 = 72{,}863$, exactly TLC's count. **Liveness.** In `WPLiveness.tla` Byzantine edges are silent, the administrator issues at most one RES value per round, and every honest action is weakly fair; $\Diamond\,\text{Committed} \neq \emptyset$ holds from every initial state (rows above). A Python model agrees on recovery: every round-0 split without a certificate recovers via RES *iff* $n - b - c \geq T$ ($25/25$ for n=4, b=1, c=0; $221/221$ for n=6, b=1, c=1, exactly at the bound; $0/79$ for n=5, b=1, c=1, one below it), matching Prop. 2(b).

Trace validation. Prototype event logs are translated to TLA$^+$ and TLC checks that the spec's `Next` admits them step by step. All six traces are admitted: split-and-RESOLVE (T20), two conflicting RES (T21), an equivocating Byzantine edge, offline edges, and two traces from real edge processes (n=16 and 32); a trace with a commit attestation moved before any prepare is rejected.

Property-based fuzz. 250 random entries (random ops, tiers, approval subsets, forged tiers, stale epochs) go through the full protocol at n=7. S2 and S1 commit 94 and reject 156, with 0 violations of ProtectedPreserved, Auth, no-default-permit and the cipher floor, and one chain at every edge; S0 (edges trust the controller) commits all 250 with 6,581 violations. The fuzz motivated one validity rule: a protected pair that existing grants already cross must fail $\text{Prot}(S')$.

Trace and fault coverage. The 40 traces and 17 faults of the design document are all exercised (enumerated in `proto/suite_policy.py` of the artifact), T17 in its IPv4 form: 52 policy-level cases (35 traces, 17 faults) pass in the emulated harness with real signatures and the real validation code, and the data-plane traces (T1, T9, T10, T12, T18, T26, T27) run on real edge processes (Section IX).

IX. Evaluation

Scope. All experiments ran on one 8-vCPU Google Compute Engine VM (AMD EPYC 7B12, four cores with two threads each, 31 GiB, Ubuntu 25.10, kernel 6.17) with real `netem` delay of 25 ms per side. WireGuard is the in-tree kernel module [8], and every logged tunnel start used it. Ubuntu's AppArmor profile for `wg` blocks key loading and the userspace socket, so the harness runs an unconfined copy of the binary. Larger n runs on the emulator. A second coder checked every incident record against its cited source. A multi-host deployment remains future work.

E1, what layer 2 buys. Attack of Prop. 5: n=12, $|\mathcal{E}_1|$=$|\mathcal{E}_2|$=6 ($D = 36$ pairs), every edge gossips every g with uniform phase, partition τ_p. Detection is the first cross-side head, so

$$\mathbb{E}[W] \approx \tau_p + \tfrac{g}{n+1} + \delta. \quad (14)$$

The window is set by τ_p, not g. Varying the fraction of edges that receive each branch (Fig. 5), S1 diverges on $k(n{-}k) \leq 36$ pairs and leaves two grants effective on a subset of the fabric; S2 never diverges: the branch held by $\geq T$=7 edges commits ($k \leq 5$: P'; $k \geq 7$: P), at k=6 the slot stalls until RES, and at most one grant is effective on part of the fabric while the minority catches up.

E2, baselines. S0: edges trust the controller. S1: signed chain with gossip (layer 1 only). S2: Witnessed Policy (layers 1 and 2). S3: BFT-replicated controllers (4 replicas, f=1,

TABLE III
E1: $\mathbb{E}[W]$ / p_{99} OF W IN SECONDS, S1 (20,000 TRIALS). S2: $D(t) = 0$, $W = 0$.

g (s)	τ_p=0	τ_p=60	τ_p=600
10	0.8 / 3.2	60.8 / 63.3	600.8 / 603.2
30	2.3 / 9.6	62.4 / 69.9	602.3 / 609.6
300	22.9 / 95.8	83.3 / 157.3	623.2 / 696.5

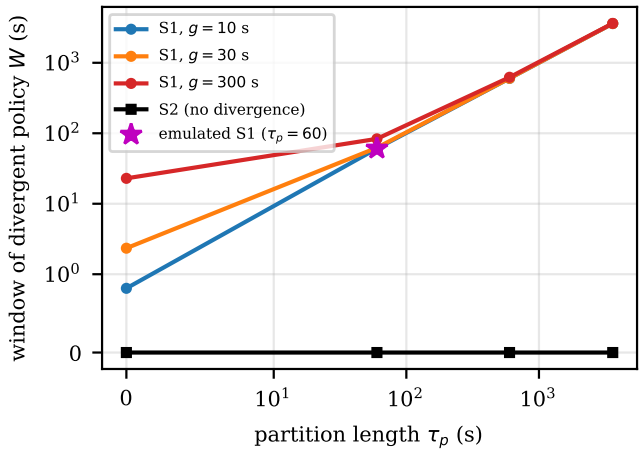


Fig. 4. E1: divergence window W vs. partition length (Monte Carlo) and an emulated protocol run.

PBFT-style ordering, edges accept on $f{+}1$ matching signed pushes [9]), implemented by us for this comparison. S3 is cheaper than S2 and more available at these parameters; its trust assumption is that fewer than $f{+}1$ controller replicas are compromised. S2 survives compromise of every controller and administrator-approval-free forgery, at $\approx 2n^2$ messages per slot and a dependence on edge availability. This is the trade the design makes; if a replicated controller cluster is acceptable, S3 is the cheaper choice.

E3, availability. Eq. (1) is exact for independent edges. Synthetic outage traces (two-state Markov edges, optionally with regional outages; no public SD-WAN outage traces were used) reproduce it for independent edges: over 20 seeds, 0.9973 ± 0.0001 vs. 0.9972 (T=7) and 0.9108 ± 0.0008 vs. 0.9104 (T=9) at a=0.9. Long and regional outages then show what the formula does not cover.

E4, incident corpus. 30 records from nine vendor names (VeloCloud and VMware, Silver Peak and Aruba share product lineages), 2020–2026, each a disclosed vulnerability or incident in an SD-WAN or network management plane (Cisco, Versa, Juniper, Fortinet, Arista VeloCloud, HPE Aruba, Silver Peak, Citrix, VMware). Codebook: capability C1 code execution on the controller (14 records), C4 authentication bypass to administrative control (9), C2 configuration or database write (5), C3 confidentiality only (2). A second coder recoded all 30 records from the cited sources and agreed on every label (κ=1.00). For nine records this was a source check of a first pass made from the summaries; for the other 21

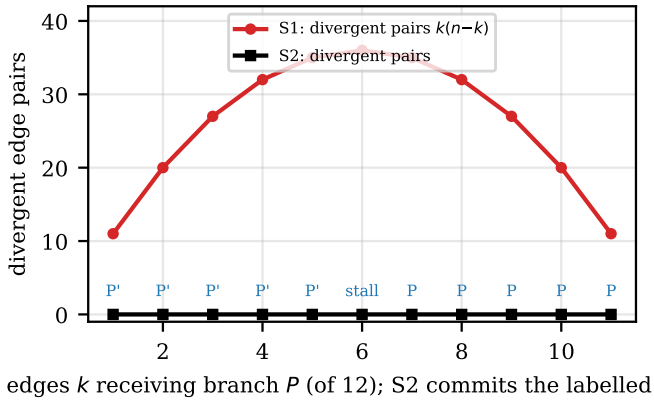


Fig. 5. E1 sweep over the split of branches (emulated protocol run, n=12, τ_p=60 s).

TABLE IV
BASELINES AT n=12, b=1 (EMULATED, δ=50 MS).

	S0	S1	S2	S3
forged entry from a compromised controller: edges accepting	12	0	0	0 / 12[†]
controller equivocation: divergent pairs	36	36	0	0
commit latency (s)	0.059	0.059	0.167	0.113
messages per slot, n=12 / 48	12/48	12/48	300/4656	91/243
verifications per edge, n=12	1	3	27	4
P(commit possible), a_{ctl}=0.999, a_{edge}=0.9	0.999	0.999	0.9962[‡]	0.999994

[†] 1 compromised replica / $f{+}1$=2 compromised replicas. [‡] a_{ctl} times Eq. (1); stuck slots also need one administrator.

it was an independent coding. Four records from the 2020 Realmode Labs series rest on a single news article. In 28 of 30 (93%) exploitation lets the attacker *originate policy* that today's edges accept; all 9 records with exploitation in the wild (e.g., Cisco CVE-2026-20127, FortiManager CVE-2024-47575, Versa CVE-2024-39717 [10]–[12]) are of this kind. If administrator approval keys are not stored on the controller, layer 1 makes edges reject such policy; it does not address the confidentiality side effects (credential and configuration theft, e.g., FortiManager, Versa, vManage SSH keys) or edge-device compromise. Records are disclosures, not breaches; exploitation is stated for 9 only. The corpus is a search-based sample, not an exhaustive census; later disclosures are not included.

E5, prototype. Python; real Ed25519 signatures and durable attestation records; every edge is an OS process in its own network namespace; the three data-plane edges run WireGuard whose peers and allowed-ips are derived from the *committed* paths and prefixes, plus nftables (default deny, ingress binding, per-grant forward and return rules) rebuilt from the chain. Control messages (TCP) and WireGuard tunnels use separate underlays, so cutting an edge's control network leaves its

TABLE V
E3: n=12, b=1; COMMIT POSSIBLE (MEAN ± 95% CI, 20 SEEDS) / 99.9TH-PERCENTILE WAIT IN HOURS (MEAN OVER SEEDS).

Outage model	separated T=7	simple T=9
1 h outages, a=0.90	0.9973±0.0001 / 0.23	0.9108±0.0008 / 2.5
10 h outages, a=0.90	0.9971±0.0005 / 2.7	0.9109±0.0035 / 23
3 correlated regions + a=0.95	0.9931±0.0004 / 1.8	0.9560±0.0012 / 11

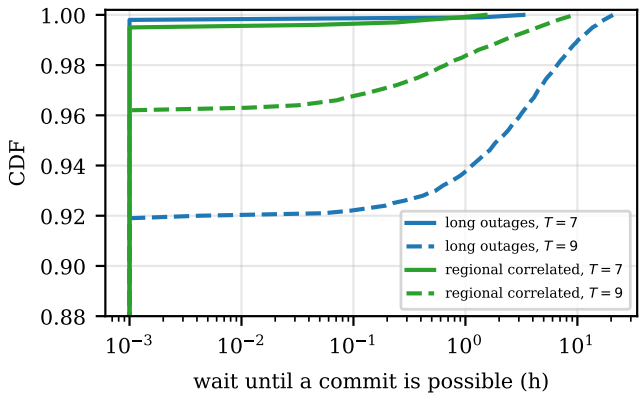


Fig. 6. E3: time until a commit is possible, separated vs. simple quorum (one run).

tunnels up. A probe in the Finance namespace opens real TCP connections to Sales:443 every 0.1 s through two WireGuard hops. n=7, b=1, T=5 unless stated. Some rules matter in the implementation although the proofs do not state them. An edge calls itself fresh only with heads from T distinct edges, not b+1. Attestations are retransmitted when an edge returns from an outage, and sync endpoints are pinned so that a wrong endpoint fails closed. The heartbeat timeout follows the measured round-trip time, and the connection probe's timeout scales with the link delay. The transport retries lost messages, and the harness waits until every edge accepts connections before it proposes. Namespace teardown completes before the next topology is built, and a kernel WireGuard device that survives `kill -9` is reused on restart.

X. ATTACKER CAPABILITIES

Layer 1 is what stops a single stolen controller credential (row 1), and it already does so with $m_\theta \geq 2$ on every tier. Layer 2 adds fork-freedom: it matters when an attacker holds enough approvals to sign two entries (rows 2 and 4) or when a compromised controller equivocates under a partition (row 3), at about $2n^2$ messages per slot and a dependence on edge availability (Table IV). The bound b assumes the attacker reaches at most b edges. Edges may share software with each other and with the management plane, so a single vulnerability can compromise several; b should be set to the size of the largest group of edges that share an exploitable component, and software diversity lowers it. With more than b compromised edges unique commit is not guaranteed (row 5).

TABLE VI
PROTOTYPE SCENARIOS (REAL PROCESSES, WIREGUARD, NFTABLES). ALL ROWS: 8-VCPU SERVER, KERNEL WIREGUARD.

Scenario	Observed
grant, then revoke	blocked before; rules installed at all three edges 0.33 s after the first prepare (edge logs) and all heads committed 0.51 s after the proposal; the probe sees the first new connection within 0.83 s (probe timeout 0.7 s); Guest and Sales:22 blocked; after revoke a new connection is blocked at 0.36 s and an established session is reset at 0.36 s; rules removed at all three data-plane edges (Fig. 7)
endpoint cut off at commit (T9)	committed by quorum; the cut-off endpoint's tunnels are up but it has no rule, so the flow is blocked there; allowed 1.3 s after its control network returns
hub failure (T10)	outage 0.8 s (3 missed heartbeats), traffic moves to the committed backup tunnel, no chain slot used; switch-back outage 0.1 s
compromised edge (T26, T27)	flow not granted is dropped at the hub's default deny; 0/40 spoofed packets carrying another site's prefix reach the hub's rules (WireGuard allowed-ips), vs. 40/40 for the edge's own prefix
`kill -9` during install (T18)	ruleset always equals a prefix of the chain (3 rounds, up to 32 grants loaded); after restart it equals the full chain in 4.0–4.4 s
late join (T14, T33)	power-on to ACTIVE 0.5–2.5 s for 10–500 slots; history 1.27 kB per slot (637 kB at 500); 30–60 MB RSS
equivocation, n=12	S1: 36 divergent pairs, fork alert at 20.5 s (τ_p=20 s); S2: none diverge, RES→commit 0.57 s, one value, also with a Byzantine process (0.58 s)
b=1, c=4 / c=5	commits with 7=T up (0.62 s) / stalls with 6; commits after heal and re-proposal
partition + lease	the cut-off edge removes the rule at 12.8 s, at its lease expiry (12.5 s after the partition); the other two edges remove it at 0.5 s (revocation), which ends end-to-end traffic at 0.33 s; catches up 0.77 s after heal (Fig. 8)

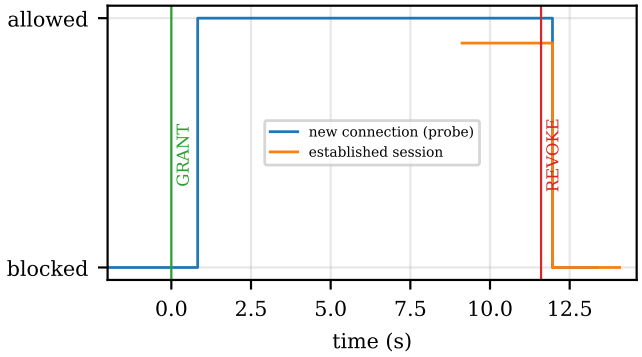


Fig. 7. Real packets over WireGuard and nftables: blocked, allowed after commit, then blocked and an established session reset by the revocation.

XI. RELATED WORK

BFT SDN control planes replicate the controller [9], [13]; we witness at the enforcing edges. Signed, threshold-authorized metadata [14]–[16], transparency logs and gossip [17], [18] and witness cosigning [19] give tamper evidence; layer 2 adds enforcement-time uniqueness. Configuration verifiers [20]–[22] check policy offline; here invariants gate commits. Verified distributed systems [23], [24] motivate the TLA$^+$ model. FastPay's lock-once consistent broadcast [3] is the precedent for the per-round prepare rule; we add round change because an administrator, not a client, must be able

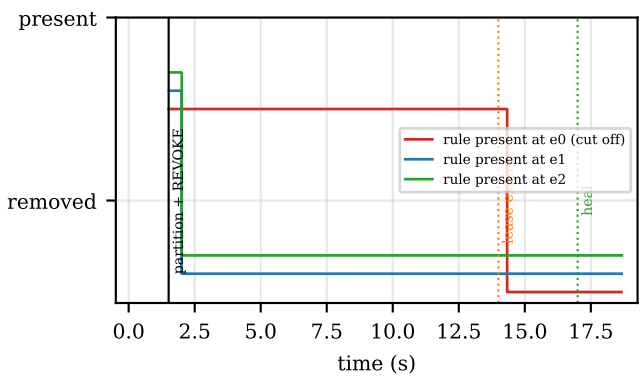


Fig. 8. Cut-off edge: its rule disappears at lease expiry; the other edges remove it when the revocation commits.

TABLE VII
COST, ONE SLOT, $b = \lfloor (n-1)/3 \rfloor$. REAL PROCESSES ($n \leq 32$) AND EMULATOR ($n \geq 100$, $\delta = 50$ MS). †MEDIAN EDGE 0.60 S; MESSAGES AND VERIFICATIONS AT THIS SIZE EXCEED THE PATTERN OF THE OTHER ROWS, AND WE HAVE NOT ISOLATED THE CAUSE.

n	latency S1/S2 (s)	S2 msgs	S2 verif./edge	S2 CPU/edge
16, server	0.088 / 0.491	512	35	68 ms
32, server	0.091 / 2.61†	3,072	91	152 ms
100	0.060 / 0.169	20,100	203	≈20 ms
200	0.060 / 0.169	80,200	403	≈39 ms
500	0.060 / 0.170	500,500	1,003	≈97 ms

to unstick a slot. Flexible BFT [25] and WHEAT [26] also separate fault classes or reweight quorums; ours separates Byzantine from offline edges for availability. P4BFT [27] compares replicated-controller outputs in the data plane, closest to S3 here. Minesweeper [22] verifies configurations offline. Our quorums are Byzantine quorum systems [28] in the dissemination style, and our one-phase result concerns claim-based recovery at $n = 3b + 2c + 1$; FaB [7] commits in one phase with $n \geq 5b + 1$. Leader-based protocols such as HotStuff [29] use $O(n)$ messages where our all-to-all phases use $O(n^2)$. Consistent network updates [30] address per-packet consistency during a change and are orthogonal. Reconfiguration of replicated state machines [31] relates to the epochs of Prop. 1.

XII. LIMITS

(i) A stolen L0/L1 key can create in-scope grants and revoke reachability (denial, not breach). (ii) Genesis is trust-on-first-use, cross-checked out of band. (iii) b must cover compromised edges and lost records (Prop. 4). (iv) Round change needs one available administrator, and an administrator key that signs RES can start ever-higher rounds and delay a stuck slot; requiring m administrator signatures on RES would bound this. (v) TLC models a single slot; epochs are covered by Prop. 1 (proof), the emulated T22 run and the epoch checker. (vi) Props. 6, 8 are analytic and E1's Monte Carlo models the attack; the data-plane scenarios ran on one 8-vCPU VM (four physical cores), so timings include CPU

TABLE VIII
OUTCOME BY ATTACKER CAPABILITY (QUALITATIVE; ROWS 1 AND 3 ARE MEASURED IN TABLE IV).

Attacker	S0	S1	S2	S3
1. controller compromised, no admin keys	any policy	rejected	rejected	rejected[a]
2. plus one key at a tier with $m_\theta = 1$	any policy	in-scope grants	in-scope grants	in-scope grants
3. controller equivocates (signed fork)	fork	fork until heads cross	no fork	no fork[a]
4. $\geq m_\theta$ admin keys	any policy	any policy	any policy, no fork	any policy, no fork[a]
5. $> b$ edges compromised	those edges	those edges	unique commit not guaranteed	those edges

[a] unless at least $f+1$ of the 4 replicas are compromised.

contention and no multi-host effects; real-process runs reach $n = 32$, and larger n is emulated. (vii) S3 is our own PBFT-style implementation; outage traces are synthetic; the incident records are disclosures, mostly without stated exploitation, coded by two coders. (viii) Layer 1 assumes administrator approval keys are not stored on the controller. (ix) Freshness takes the $(b+1)$-voucher target slot over T heads, so an edge whose heads contain a single honest committer of a revocation can stay fresh without it; Prop. 8 covers connected edges (a) and edges that are not fresh (b), and carrying commit certificates in heads would close the gap. (x) One lease length (about 12.5 s) is evaluated; the trade-off between lease length and data-plane availability under partition is not.

XIII. CONCLUSION

Layer 2 gives unique commit with $n \geq 3b + 2c + 1$ edges, claim-based one-phase recovery cannot, and revocation is bounded by $t_c + 4\delta + g + d_{\text{enf}}$ (connected) or $\lambda_\gamma + \sigma + d_{\text{enf}}$ (partitioned). The prototype, with real edge processes, WireGuard and nftables, confirms the safety scenarios (the 40 traces and 17 faults of Section VIII) and the cost shape: S2 costs $\approx 2n^2$ messages and $\approx 3\delta$ per slot, buys immunity to full controller compromise, and a replicated controller (S3) is cheaper when its $f+1$ trust assumption is acceptable. A multi-host deployment will test the timing bounds.

REFERENCES

[1] A. Clement, M. Kapritsos, S. Lee, Y. Wang, L. Alvisi, M. Dahlin, and T. Riche, "UpRight cluster services," in *ACM SOSP*, 2009.
[2] M. Castro and B. Liskov, "Practical Byzantine fault tolerance," in *USENIX OSDI*, 1999.
[3] M. Baudet, G. Danezis, and A. Sonnino, "FastPay: High-performance Byzantine fault tolerant settlement," in *ACM AFT*, 2020, pp. 163–177.
[4] S. Gordeychik, "SD-WAN threat landscape," arXiv:1811.04583, 2018.
[5] J. Kim, M. Seo, E. Marin, S. Lee, J. Nam, and S. Shin, "Ambusher: Exploring the security of distributed SDN controllers through protocol state fuzzing," *IEEE Trans. Inf. Forensics Security*, vol. 19, pp. 6264–6279, 2024.
[6] P. A. Thomas, "Cisco patches SD-WAN flaw amid evidence of active exploitation," CSO Online, Jun. 2026.
[7] J.-P. Martin and L. Alvisi, "Fast Byzantine consensus," *IEEE Trans. Dependable Secure Comput.*, vol. 3, no. 3, pp. 202–215, 2006.
[8] J. A. Donenfeld, "WireGuard: Next generation kernel network tunnel," in *NDSS*, 2017.
[9] E. Sakic, N. Derić, and W. Kellerer, "MORPH: An adaptive framework for efficient and Byzantine fault-tolerant SDN control plane," *IEEE J. Sel. Areas Commun.*, 2018.

[10] BleepingComputer, "Chinese Volt Typhoon hackers exploited Versa zero-day to breach ISPs and MSPs," CVE-2024-39717, 2024.
[11] P. Paganini, "FortiJump flaw CVE-2024-47575 exploited in zero-day attacks since June 2024," Security Affairs, Oct. 2024.
[12] Rapid7, "Cisco Catalyst SD-WAN Controller and Manager authentication bypass (CVE-2026-20127)," Vulnerability database, 2026.
[13] M. Xu *et al.*, "Curb: Trusted and scalable software-defined network control plane for edge computing," in *IEEE ICDCS*, 2022.
[14] J. Samuel, N. Mathewson, J. Cappos, and R. Dingledine, "Survivable key compromise in software update systems," in *ACM CCS*, 2010.
[15] M. Lepinski and S. Kent, "An infrastructure to support secure internet routing," RFC 6480, 2012.
[16] Tailscale, "Tailnet lock white paper," https://tailscale.com/kb/1230/tailnet-lock-whitepaper.
[17] B. Laurie, A. Langley, and E. Kasper, "Certificate transparency," RFC 6962, 2013.
[18] L. Chuat, P. Szalachowski, A. Perrig, B. Laurie, and E. Messeri, "Efficient gossip protocols for verifying the consistency of certificate logs," in *IEEE CNS*, 2015.
[19] E. Syta *et al.*, "Keeping authorities "honest or bust" with decentralized witness cosigning," in *IEEE S&P*, 2016.
[20] A. Fogel *et al.*, "A general approach to network configuration analysis," in *USENIX NSDI*, 2015.
[21] A. Khurshid *et al.*, "VeriFlow: Verifying network-wide invariants in real time," in *USENIX NSDI*, 2013.
[22] R. Beckett, A. Gupta, R. Mahajan, and D. Walker, "A general approach to network configuration verification," in *ACM SIGCOMM*, 2017.
[23] C. Hawblitzel *et al.*, "IronFleet: Proving practical distributed systems correct," in *ACM SOSP*, 2015.
[24] J. R. Wilcox *et al.*, "Verdi: A framework for implementing and formally verifying distributed systems," in *ACM PLDI*, 2015.
[25] D. Malkhi, K. Nayak, and L. Ren, "Flexible Byzantine fault tolerance," in *ACM CCS*, 2019.
[26] J. Sousa and A. Bessani, "Separating the WHEAT from the chaff: An empirical design for geo-replicated state machines," in *IEEE SRDS*, 2015.
[27] E. Sakic *et al.*, "P4BFT: Hardware-accelerated Byzantine-resilient network control plane," arXiv:1905.04064, 2019.
[28] D. Malkhi and M. Reiter, "Byzantine quorum systems," *Distributed Computing*, vol. 11, no. 4, pp. 203–213, 1998.
[29] M. Yin, D. Malkhi, M. K. Reiter, G. G. Gueta, and I. Abraham, "HotStuff: BFT consensus with linearity and responsiveness," in *ACM PODC*, 2019.
[30] M. Reitblatt, N. Foster, J. Rexford, C. Schlesinger, and D. Walker, "Abstractions for network update," in *ACM SIGCOMM*, 2012.
[31] L. Lamport, D. Malkhi, and L. Zhou, "Reconfiguring a state machine," *ACM SIGACT News*, vol. 41, no. 1, pp. 63–73, 2010.